RAPPORTO DI ASSESSMENT DI SICUREZZA

Analisi delle Vulnerabilità e Network Scanning

Analista: Simone Meola
Target: Metasploitable 2 (192.168.56.102)
Attaccante: Kali Linux (192.168.56.101)

Sintesi Esecutiva
Il presente documento riporta i risultati dettagliati dell'attività di valutazione delle vulnerabilità svolta su macchina virtuale Metasploitable 2 all'interno di un ambiente isolato VirtualBox. L'audit ha identificato molteplici criticità ad alto rischio (CVSS 9.8 - 10.0) che consentono l'esecuzione remota di codice non autorizzato.

1. Topologia ed Ambiente di Test

L'infrastruttura di analisi è stata configurata tramite scheda di rete *Solo-Host (Host-only)* per garantire isolamento e connettività bidirezionale:

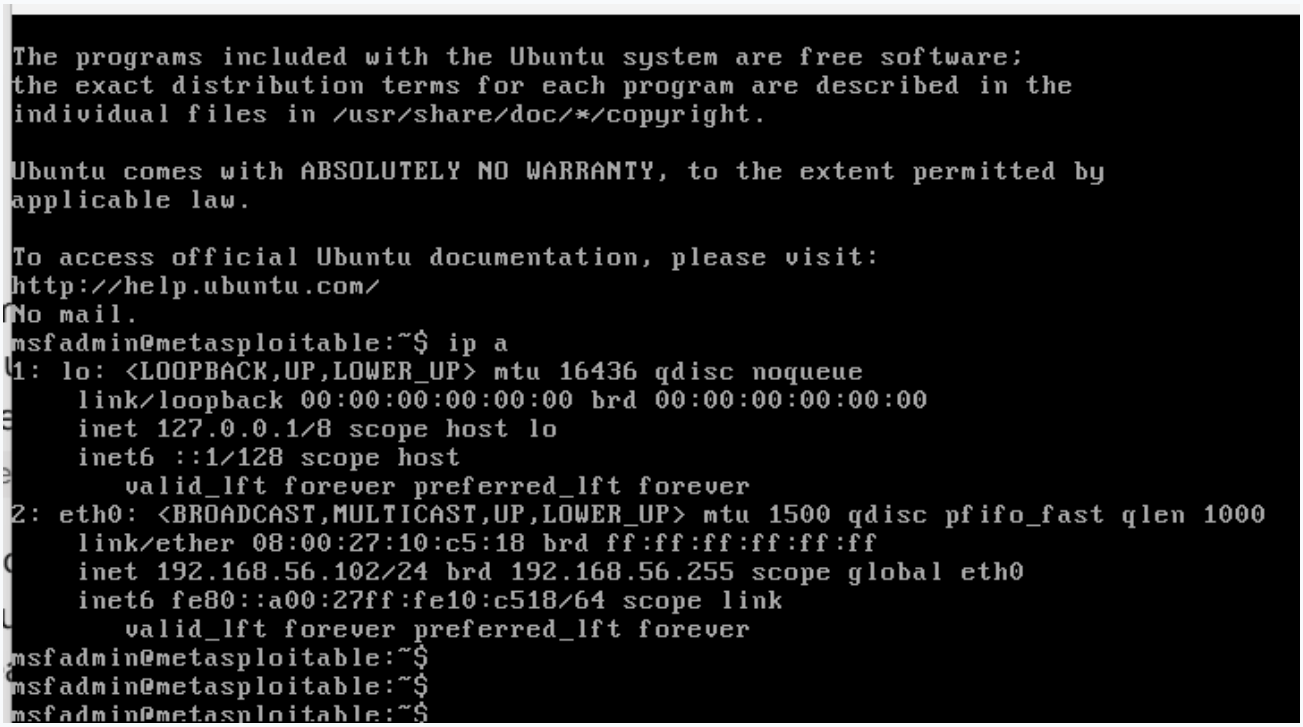


Figura 1: Output `ip a` su Metasploitable (IP target 192.168.56.102)

2. Fasi di Network Discovery (Nmap)

È stato eseguito un footprinting completo dei servizi in ascolto mediante Nmap:

```
sudo nmap -Pn -n -sV -sC 192.168.56.102
```

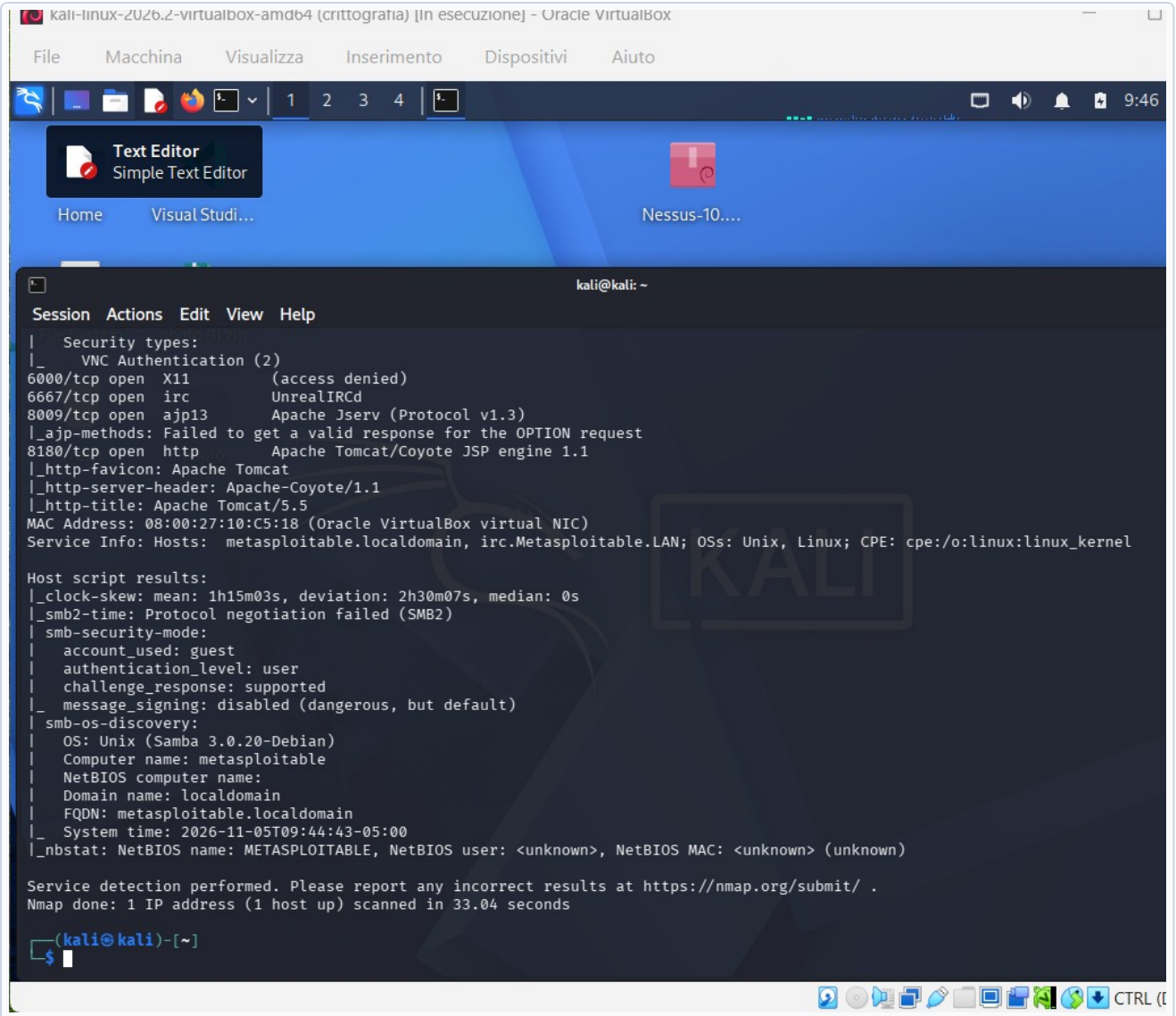


Figura 2: Risultati della scansione Nmap (completata in 33.04 secondi)

Principali Servizi Identificati:

Porta	Servizio	Versione Software	Vulnerabilità Note
`21/tcp`	FTP	vsftpd 2.3.4	Backdoor sorvegliata da smiley `:)` (Root Shell TCP 6200)
`139/445`	SMB	Samba 3.0.20-Debian	RCE tramite Username Map Script
`6667/tcp`	IRC	UnrealIRCd	Backdoor sorvegliata da prefisso `AB;`
`8180/tcp`	HTTP	Apache Tomcat/Coyote 1.1	Credenziali manager predefinite/deboli

3. Scansione Automatizzata delle Vulnerabilità (Nessus)

L'analisi automatizzata con Tenable Nessus Essentials ha confermato ed esteso i rilievi di Nmap. La scansione di ti
Basic Network Scan è durata esattamente **27 minuti** utilizzando l'algoritmo di valutazione **CVSS v3.0**.

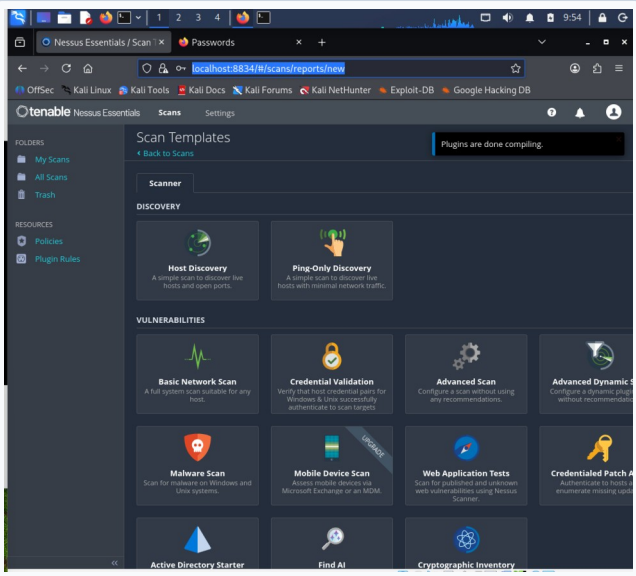


Figura 3: Selezione Modello Basic Network Scan

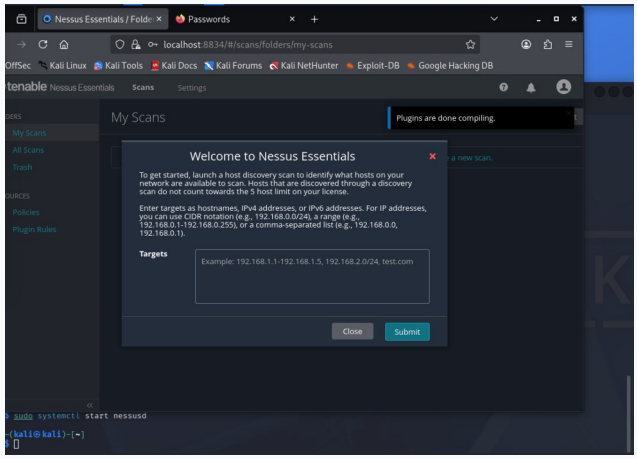


Figura 4: Inizializzazione motore Nessus

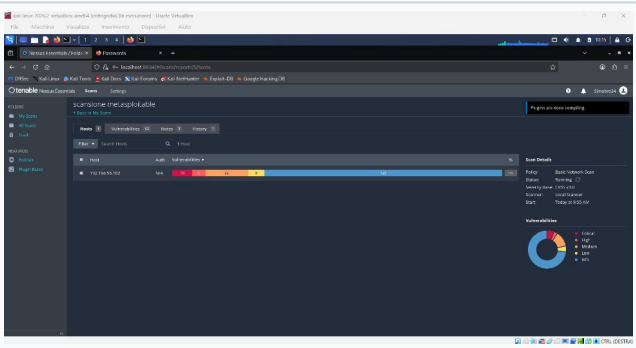


Figura 5: Scansione Nessus in fase di avanzamento

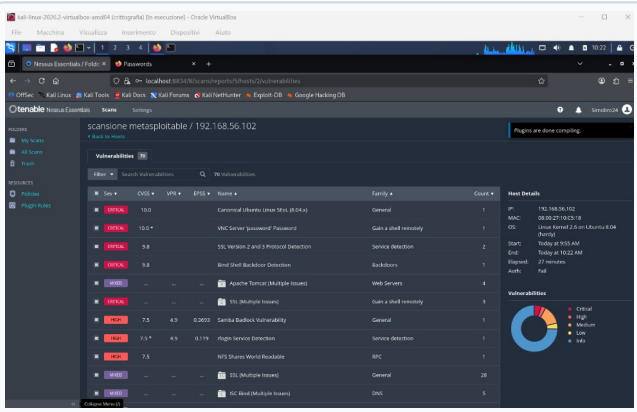


Figura 6: Report finale delle 70 vulnerabilità rilevate

Sintesi del Profilo di Rischio:

Severità	CVSS	Vulnerabilità Rilevata	Impatto Potenziale
CRITICAL	10.0	VNC Server 'password' Password	Accesso grafico completo senza autenticazione valida
CRITICAL	10.0	Canonical Ubuntu Linux SEoL (8.04)	Privilege Escalation a livello kernel per mancati aggiornamenti
CRITICAL	9.8	Bind Shell Backdoor Detection	Accesso shell remoto diretto con privilegi elevati
HIGH	7.5	Samba Badlock / Rlogin Service	Intercettazione del traffico e sessioni non protette

4. Concetti Teorici ed Exploitation (Metasploit)

Il report sintetizza i concetti chiave utili per la successiva fase di penetration testing con **Metasploit Framework**:

- **Exploit:** Codice che sfrutta una falla software per alterare il normale flusso del programma.
- **Payload:** Componente eseguito dopo l'avvenuto exploit per fornire controllo remoto (es. shell meterpreter).
- **Backdoor:** Accesso segreto intenzionale o malevolo bypassando i meccanismi di autenticazione standard.

> **Conclusione e Raccomandazioni**
> Il sistema analizzato presenta gravissime criticità. Si raccomanda di isolare o dismettere il target, disabilitare i servizi legacy non cifrati (Rlogin, Telnet, VNC banale) e aggiornare il sistema operativo a una versione con supporto di sicurezza attivo.